Access Control and Password Policy

Document control	
Company	LogistiComp S.A.
Document ID	LC-POL-002
Version	2.4
Classification	Internal – may be shared with customers under NDA
Owner	Chief Information Security Officer (CISO)
Approved by	Information Security Steering Committee (ISSC)
Effective date	15 January 2026
Next review	January 2027

1. Purpose

This policy defines how access to LogistiComp information and systems is requested, granted, reviewed and removed, and sets the minimum requirements for authentication, including passwords and multi-factor authentication. It implements Section 9 of the Information Security Policy (LC-POL-001).

2. Scope

This policy applies to:

- all LogistiComp employees, contractors and third parties with access to LogistiComp systems ("workforce users");
- all corporate systems, the development and test environments, and the LogistiComp WMS production environment;
- authentication of customer users to LogistiComp WMS (Section 9).

3. Principles

- **Least privilege:** users receive only the access they need to perform their role.
- **Need-to-know:** access to Confidential and Restricted information is limited to people with a business need.
- **Role-based access control:** access is assigned through predefined roles, not granted to individuals one by one wherever possible.
- **Segregation of duties:** no single person can both develop a change and approve its deployment to production (see LC-POL-007).

4. User Accounts

- Every workforce user has a unique, named personal account. Shared or generic accounts are not permitted.
- Workforce identities are managed centrally in Microsoft Entra ID, which provides single sign-on (SSO) to corporate systems.
- Service accounts used by applications must have a named owner, must not be used for interactive login, and have their credentials stored in Azure Key Vault.
- Accounts that have not been used for 90 days are disabled automatically.

5. Joiners, Movers and Leavers

- **Joiners:** access is requested through the IT service desk and must be approved by the user's line manager and, for each system, by the system owner. No access is granted before the confidentiality agreement is signed (LC-POL-001, Section 8).
- **Movers:** when a user changes role, their access is reviewed within 5 working days, and access no longer needed for the new role is removed.
- **Leavers:** all access is revoked no later than the end of the user's last working day. In the case of a dismissal, access is revoked immediately.

6. Privileged Access

- Administrators use a separate privileged account, which is distinct from the account they use for email and everyday work.
- Access to the production environment is granted just in time through a bastion host. Each elevation must be approved, is limited to a maximum of 8 hours, and expires automatically.
- All privileged sessions in the production environment are logged and the logs are sent to the SIEM (LC-POL-001, Section 11.3).
- The number of people with permanent administrative rights to the Azure production subscription is kept to a minimum and reviewed quarterly.

7. Access Reviews

- Access rights to the production environment are reviewed quarterly.
- Access rights to all other systems are reviewed every six months.
- Reviews are performed by system owners. Access that is no longer justified is removed within 5 working days of the review.

8. Authentication Requirements for Workforce Users

8.1 Multi-Factor Authentication

Multi-factor authentication (MFA) is **mandatory** for all workforce users, for access to all corporate systems, to the Azure management portal and to the production environment. There are no exceptions to this requirement.

Approved second factors are an authenticator app with number matching, or a FIDO2 hardware security key. SMS and voice calls are **not** accepted as second factors. Administrators of the production environment must use a FIDO2 hardware security key.

Access to corporate systems is only allowed from Company-managed devices that meet the Company's device compliance rules, enforced through conditional access policies.

8.2 Password Requirements

Passwords for workforce accounts must meet the following requirements:

Requirement	Rule
Minimum length	**12 characters**
Maximum length	At least 64 characters must be supported
Composition	No mandatory mix of character types; passphrases are encouraged
Banned passwords	Passwords are checked against a list of commonly used and known breached passwords, and these are rejected
Password history	The last 5 passwords cannot be reused
Expiry	No periodic forced change; a password must be changed immediately if compromise is suspected
Storage	Passwords are never stored in plain text; they are stored only as salted, one-way hashes

Service account and other non-human credentials must be at least 32 characters long, randomly generated and stored in Azure Key Vault.

Users must not share their passwords with anyone, including IT staff, and must not write them down or store them outside the Company-approved password manager.

8.3 Account Lockout

After **5 consecutive failed login attempts**, the account is locked for 15 minutes. Repeated lockouts generate an alert to the security team. Accounts can be unlocked earlier by the IT service desk only after the user's identity has been verified.

8.4 Sessions

Workstations lock automatically after 10 minutes of inactivity. Sessions on the bastion host to the production environment are terminated after 30 minutes of inactivity.

9. Customer Access to LogistiComp WMS

9.1 Authentication Options

Customers can choose how their users sign in to LogistiComp WMS:

- **Single sign-on (SSO)** with the customer's own identity provider, using SAML 2.0 or OpenID Connect. In this case, password and MFA rules are set by the customer's identity provider.
- **Local LogistiComp WMS accounts.** In this case, the same password rules as in Section 8.2 apply (minimum 12 characters, banned-password check, history of 5), and accounts are locked after 5 consecutive failed login attempts.

For local accounts, MFA with an authenticator app (time-based one-time passwords) is available, and the customer's administrators can make it mandatory for all users in their tenant.

9.2 Customer User Management

Each customer manages its own users through the administration screen of its tenant. LogistiComp WMS provides the following predefined roles: Administrator, Warehouse Manager, Operator and Read-only. Customer administrators are responsible for assigning roles and for removing users who leave their organisation.

9.3 LogistiComp Support Access to Customer Tenants

LogistiComp support staff can only access a customer's tenant to resolve a support request raised by that customer. Each support access session must be linked to a support ticket, is limited to 24 hours, and is recorded in the tenant's audit log, which is visible to the customer's administrators.

10. Remote Access

Workforce users can work remotely. Remote access to corporate systems uses the same SSO, MFA and device compliance controls as access from the office. The production environment can only be reached through the bastion host, from Company-managed devices.

11. Exceptions and Enforcement

Exceptions to this policy, other than to the MFA requirement in Section 8.1, follow the exceptions process in LC-POL-001, Section 18. Violations of this policy may result in disciplinary action.

12. Review

This policy is reviewed at least annually by the CISO and approved by the ISSC.